HL-CYB-001

Test plan and requirement traceability

Enterprise Zero Trust Security Architecture

Document version c01a987e29cf

Operational tests: NOT TESTED. This plan defines future lab validation; it is not a record of executed security tests. Authorized documentation tasks may run repository checks (T00 and repository-only T17). Every lab, security, remote-access, and recovery test needs explicit approval for the relevant stage. Home and production systems are never targets.

A functional test checks that required work succeeds. A negative test checks that a named unauthorized action is denied. A recovery test checks that an agreed service can be restored. Use the glossary and individual task reports to distinguish these planned tests from actual evidence.

1. Test governance and evidence

For each future test, freeze the lab-only source/target, identity/device context, version, expected outcome, bounded action/rate, independent observation, stop condition, recovery method, and evidence ID. Use evidence conventions. Evidence stays private until sanitized and manually reviewed. A negative result must show denial from the intended control, not merely a disconnected service or a DNS typo; first establish an approved working control case.

Use PASS, FAIL, or NOT TESTED and explain any blocked or skipped case. Record an exception before assessment, with owner approval, risk, and revised scope. An unexecuted case never counts as passed. R14 requires every mandatory case executed, 100% of critical cases passed, at least 95% of applicable noncritical cases passed, and no unresolved high-severity issue. Count the declared individual cases, state the denominator, and do not round away a failure. T20 includes separate owner UAT; engineering cannot award it on the owner's behalf.

2. Test catalog

2.1. T00 - Bootstrap documentation and Git validation

- Scope: Task 001; critical; R11/R15/R16. Run the standard-library validator, its focused negative-case unit tests, whitespace checks, and independent file/link/content review. Inspect all proposed tracked paths and the staged diff/history before publication.
- Expected: required files/sections, valid local destinations/anchors, complete requirement traceability, 100-point rubric, no selected publication findings, and no infrastructure execution. After publication, verify public visibility, `main`, clean tracking, exact local/remote SHA equality, and actual Actions result.
- Independent observation: Git tree/history and remote metadata/Actions run, separate from the validator's output. Evidence: Task 001 completion report and repository-only check record. Owner UAT remains pending until stated by the owner.

2.2. T01 - Protected-network isolation

- Future scope: A-D/K; critical; R01/R04. Inspect cables, bridge ports, guest NICs, host/guest routes, forwarding, firewall aliases/rules, IPv6, and other admin-station adapters. Confirm no production trust/sync/identities.
- Expected: no unauthorized physical/virtual/overlay path to home/production; only the approved administrative path and separately gated egress exist. With separately approved mock endpoints representing a protected zone, attempt one bounded connection and observe denial.
- Independent observation: effective route/bridge/rule review plus a corresponding mock-boundary log/counter. Never send traffic to a real protected address/domain. Evidence must distinguish configuration proof from the mock behavioral test.

2.3. T02 - Egress, DNS, and exposure control

- Future scope: D/K; critical; R01/R04. Inspect permitted external destinations, resolver restrictions, firewall-originated traffic, NAT/automatic rules, IPv6, UPnP/NAT-PMP, and inbound listeners. Egress-enabling approval is a prerequisite.
- Expected: offline baseline remains disconnected or approved egress reaches only named dependencies; no inbound admin/port forward or protected destination permit exists. Test allowed vendor dependency and denied lab-mock alternate resolver/destination only within scope.
- Independent observation: rule/state/counter inspection and resolver/vendor result; inspect actual protected-target aliases privately without probing them. Unavailable isolated egress means BLOCKED, not relaxed policy.

2.4. T03 - Hardware, capacity, and media readiness

- Future scope: A/B; critical; R02. Reconcile supplied specs with existing OS/firmware/physical observations, exact disk ownership, backup/console recovery, media integrity, and usable capacity. No disk write during the read-only readiness task.
- Expected: an approved resource ledger fits measured RAM/storage, reserves at least 12 GiB host RAM and 80 GiB disk free, and identifies all blocking uncertainty. Verify the guest ceilings independently by summing the allocation table.
- Independent observation: physical/firmware or storage UI versus inventory output; vendor integrity value versus downloaded media digest. Record measurements privately and publish synthetic summaries.

2.5. T04 - Administrative access and recovery

- Future scope: B/D/K; critical; R03. Verify named admin/MFA and effective roles, management bind addresses, lab-only admin source, local console recovery, and ordinary-user denial using approved mock contexts.
- Expected: ordinary users cannot administer the hypervisor/firewall; authorized named administration works; recovery works without opening management to all networks. Identify MFA coverage gaps explicitly.
- Independent observation: successful/denied session plus management audit log and role inspection. Never disable the firewall globally for this test.

2.6. T05 - Required inter-zone workflows

- Future scope: D/F/H/K; noncritical; R04/R08. Run one approved business/service flow for each implemented permit F01-F10, with a known listening destination, correct identity, DNS, and service.
- Expected: each permit works only for its intended source, destination, and service. Failed dependencies are defects; they do not justify a broad allow rule.
- Independent observation: application-level result plus matching firewall/host policy log/counter. Record each flow case separately in the denominator.

2.7. T06 - Default deny and lateral restrictions

- Future scope: D/H/K; critical; R04/R08. With a known working control case, try a wrong source, wrong port/resource, ordinary-user management path, and same-zone unauthorized service using lab-only targets.

- Expected: each case is denied by the intended network/host/application control; unlisted inter-zone traffic and same-zone resource authorization remain restricted. Inspect state/cached-session behavior after a policy change.
- Independent observation: bounded connection result plus effective policy and denial audit. Record both overlay/direct-IP and hostname cases when implemented; no broad scans.

2.8. T07 - Directory DNS and domain services

- Future scope: E/F/K; noncritical; R05. Check the separate forest, DNS forward/reverse/service records, lab-only resolver settings, time source, and version-specific AD service permits. Resolve a synthetic record and exercise an approved member logon.
- Expected: `ad.lab.test` services work without corporate trust/sync/DNS; clients cannot silently substitute a home/corporate resolver. Real protected resolvers are inspected as excluded configuration, never probed.
- Independent observation: directory/DNS configuration versus client resolution/logon and server event. Capture actual addresses only privately.

2.9. T08 - GPO and identity lifecycle

- Future scope: E/F/K; noncritical; R05/R08. Count six synthetic standard users, three role groups, two separate privileged accounts; inspect delegated memberships and resultant GPO on the member endpoint. Test a dedicated synthetic joiner/mover/leaver scenario.
- Expected: intended baseline/rights apply, ordinary users lack privileged groups, and lifecycle changes generate audit events. No corporate object or cloud synchronization is present.
- Independent observation: resultant policy/user session versus GPO/group configuration and directory audit. Do not perform lockout testing against recovery accounts.

2.10. T09 - Endpoint baseline and least privilege

- Future scope: F/K; noncritical; R06. Verify supported Windows/Linux versions, patch status, single-NIC attachment, host firewall, unnecessary services, and standard-user/admin separation.
- Expected: standard users cannot perform an approved harmless privileged action; authorized administration works; local/forwarding bypasses are absent. Linux domain join is assessed only if approved and implemented.
- Independent observation: user-level behavior versus OS policy/service/firewall inspection. Do not claim vulnerability assessment from a version list.

2.11. T10 - PKI issuance and trust

- Future scope: G/K; critical; R07. Inspect root NIC absence/power state, separate issuing CA, template/enrollment permissions, CA backup custody, chain/AIA/CDP, and lab-only trust. Issue a synthetic application TLS certificate.
- Expected: approved application accepts correct hostname/usage/chain and rejects an untrusted or wrong-name/expired test certificate. Only approved lab systems trust the root.
- Independent observation: certificate/template review versus actual TLS relying-application behavior. No production trust-store modification.

2.12. T11 - Certificate revocation

- Future scope: G/K; critical; R07. Revoke a dedicated test leaf, publish a fresh CRL, document validity/cache state, and test the selected revocation-enforcing lab application. AIA/CDP URLs must be reviewed lab destinations.
- Expected: the valid control certificate succeeds and the revoked leaf fails in the relying application within its declared refresh behavior. Do not change DC time or infer rejection from a certificate dump alone.
- Independent observation: CA/CRL evidence plus application rejection and chain validation; report soft-fail/unsupported clients as limitations.

2.13. T12 - Business-role matrix and access revocation

- Future scope: H/K; critical; R08. Execute all twelve cases below using synthetic contexts and application-level actions. Measure revocation from committed policy change to actual denial for both existing and new sessions.
- Expected: every allow/deny matches the approved matrix; target revocation is at most fifteen minutes, including declared cache/session treatment. No network permit substitutes for application authorization.
- Independent observation: effective group/application policy plus application result/audit and independently recorded elapsed time. Matrix entries are future test expectations, not results.

Table 1. Test catalog

Case	Synthetic context	Resource/action	Expected
C01	Analyst	Read synthetic report through TLS	Allow
C02	Analyst	Modify application configuration	Deny
C03	Analyst	Administer hypervisor/firewall	Deny
C04	Engineer standard identity	Read approved project resource	Allow
C05	Engineer approved admin context	Maintain named test service	Allow
C06	Engineer standard identity	Administer directory or CA	Deny
C07	Named administrator on admin path	Manage approved infrastructure	Allow
C08	Administrator identity on ordinary endpoint	Use prohibited privileged logon path	Deny
C09	Unauthorized synthetic user	Read protected report	Deny
C10	Authorized user, wrong service/port	Access unlisted application path	Deny
C11	Same-zone unauthorized endpoint/user	Reach restricted peer resource	Deny
C12	Revoked synthetic user	Continue/reopen previously allowed resource	Deny within declared target

2.14. T13 - Tailscale pilot

- Future scope: I/K; critical; R09/R08. Verify independent lab identity/tailnet before enrollment, explicit restrictive effective policy, tag owners, MFA, selected device, DNS/routes, no subnet/exit node, and host/overlay controls.
- Expected: one named resource works for the authorized user/device; unauthorized user/resource and revoked-user cases fail. Record existing-session timing and plan-specific posture/log visibility.
- Independent observation: policy/admin records versus actual application session and host/vendor audit. No real protected-target probe; run only one remote pilot at a time.

2.15. T14 - Twingate pilot

- Future scope: I/K; critical; R09/R08. Verify a separate lab network, connector placement, private token handling, explicit resource/port restrictions, group/MFA settings, DNS, and connector firewall limits.
- Expected: the same scoped authorized/unauthorized/revoked cases as T13; connector cannot reach management/directory except specifically required reviewed dependencies. No inbound public service is introduced.
- Independent observation: effective vendor resource/group policy and independent connector-zone firewall/log evidence versus application behavior. Document unsupported features rather than silently accepting broader access.

2.16. T15 - Time correlation

- Future scope: J/K; noncritical; R10. Compare all six source classes to the chosen lab time authority using supported read-only observations. Verify domain hierarchy and standalone host settings.
- Expected: every measured offset is at most two seconds; UTC timestamps correlate. Offline or vendor time visibility limitations are explicit and block the applicable claim.
- Independent observation: source settings versus measured offsets and collector correlation. Never shift domain time merely to test certificate expiry.

2.17. T16 - Collection, detection, and retention

- Future scope: J/K; noncritical; R10. Generate twenty approved benign synthetic events across all six classes. Record source/collector/search timestamps. Test one lab source interruption, log access denial, and rotation/quota behavior.
- Expected: at least nineteen events searchable within five minutes, every class represented, source interruption detected, and retention capacity supports thirty days with margin. Distinguish calculated capacity from elapsed retention evidence.
- Independent observation: source records versus collector searches, timestamps, ACLs, storage ledger, and health alert. Raw data stays private; no real attack traffic is required.

2.18. T17 - Publication and supply-chain review

- Scope: repository-only during Task 001; critical; R11/R16. Scan candidate/staged/history content for selected secret patterns, sensitive filenames, real addresses, email/tenant details, binary artifacts, production exports, and proprietary source. Review workflow permissions/action pin and absence of lab credentials.
- Expected: only individually reviewed public-safe artifacts; no real internal addresses or tokens in files, Git URLs, commits, or evidence. No license selected without approval. Unknown binary types fail closed.

- Independent observation: manual full-content review and Git tree/history inspection. The built-in pattern scanner cannot prove absence of every secret or classify proprietary code; operational media/integrity reviews occur only in approved later stages.

2.19. T18 - Bounded automation

- Future scope: L; noncritical; R12. Review two operations/target allowlists/credential handling, run syntax and meaningful rejection tests, apply on one approved target, inspect actual state, and repeat.
- Expected: intended first-run behavior, zero unintended second-run changes, safe failure on invalid target/input, private sensitive output, and successful scoped rollback demonstration.
- Independent observation: desired state inspected through another supported tool, not just the automation's own success flag. Check/diff mode is not proof of safe normal execution.

2.20. T19 - Isolated recovery

- Future scope: L; critical; R13. Verify backup age/encryption/key access/off-compute location; restore representative identity/application scope into disconnected networks using supported procedures. Do not run duplicate live DC identities.
- Expected: data age at most 24 hours and full scoped service restoration within four hours; DNS/authentication, PKI/revocation dependencies, authorization, and synthetic data consistency pass. List assets not recovered by the drill.
- Independent observation: separate timing and service/data checks versus backup/restore output. Do not overwrite the sole valid backup or rejoin protected networks to complete recovery.

2.21. T20 - Final traceability, report, and owner UAT

- Future scope: K/L; critical; R14/R15. Review every requirement against tests, actual evidence, defects, accepted exceptions, architectural differences, and final claims. Apply the 100-point rubric only to demonstrated outcomes.
- Expected: accurate engineering verdict with no high-severity unresolved issue, honest limitations, evidence-backed resume statements, and a **separate explicit owner UAT decision**. Pending UAT is not acceptance.
- Independent observation: traceability/evidence review and owner business workflow confirmation; document who performed each review. Task 001 establishes this plan and earns no operational result.

3. Coverage index

Table 2. Coverage index

Requirement	Primary tests
R01	T01, T02
R02	T03
R03	T04
R04	T01, T02, T05, T06
R05	T07, T08

Requirement	Primary tests
R06	T09
R07	T10, T11
R08	T06, T08, T12, T13, T14
R09	T13, T14
R10	T15, T16
R11	T00, T17
R12	T18
R13	T19
R14	T01-T20, assessed through T20
R15	T00, T20
R16	T00, T17